

CS4230 – CyberCrime, IT Security and Risk

Project Assignments – Theme I

Cybersecurity risks for organizations

Mathias LEFEBVRE
malef6335@usn.no

University of South-Eastern Norway, Campus Kongsberg

May 20, 2026

1 Introduction

For this assessment, we are going to review the City of Jonesboro Password Policy (dated September 27, 2017), a public document from the IT Policies & procedures section of the City of Jonesboro, Arkansas' official website [1]. This policy governs employee password practices to secure municipal IT systems by sharing strict rules on password construction, usage, sharing, and changes. While the policy demonstrates good intent, it relies on 2017 rules, and we are going to evaluate their relevance in today's context. In a first time, we are going to assess this policy regarding its strengths and weaknesses. Then, in a second time, we are going to suggest changes and explain the motivation behind these changes.

2 Assessment

To begin this assessment, we first go through the good parts of the policy. Even if this policy is old, there are still some guidelines relevant today. Indeed, the policy forbids the use of obvious keyboard sequences, such as qwerty, azerty 123456 etc... With the same idea, the password should not include guessable data or OSINT (OpenSource INTelligence) available data, such as the name of your city, your child's name, or your date of birth, etc... This is a good guideline because it can protect the users against password bruteforce (e.g. rockyou password list) or against more advanced targeted password attack.

The confidentiality section is also well designed with only minor room for changes. Passwords should be considered strictly confidential data and treated with the same discretion as any of the organisation's proprietary information. Users must not share their passwords with anyone or be written down and left unsecured. The idea is to avoid data stealing in case of physical breach. The policy indicates the users must not check the "save password" box when authenticating to applications. this can avoid cookie stealing in case of malware infection. On the same principle, passwords must not be used for different systems and/or accounts. And, no password should be sent via email. Because in case of data leak then all the accounts that use the compromised password are at risk. Lastly, inside the Network Access and Authentication policy, they add an auto logout mechanism after 15 minutes of inactivity, reducing the risk of unauthorised access in case a user forgets to log out. All these guidelines are relevant, even in 2026, and should not be modified.

We are now going to assesses the weaknesses of the policy. The main concern lies in the password construction requirements, which are outdated by current standards. The policy requires passwords to be at least eight characters long and to include a combination of uppercase and lowercase letters, numbers, and special characters.

It also states that passwords should not contain words found in a dictionary. In addition, the policy requires passwords to be changed every 90 days and prevents users from reusing any of their previous 24 passwords. Finally, the document does not mention the use of password managers or multi-factor authentication. Overall, this policy is not up to date and must be revised, these requirements are not aligned with the more recent NIST password guidelines that we will develop in the next sections.

From a human-factors perspective, the policy also has important limitations. Secure behaviour depends on ability, motivation, and prompts, and that users are more likely to comply when security requirements are easy to adopt. The Jonesboro password rules place a high cognitive burden on users by requiring complex passwords, regular changes and having different passwords each time. This may encourage insecure strategies such as reuse, writing passwords down, or relying on predictable variations. In this sense, the policy is technically strict but not fully user-centred.

3 Proposed Changes/Additions

In order to address the potential issue and update this policy, I suggest modifying the original text to add these reviewed rules :

4.1 Construction:

- Passwords must be at least 12 characters long (16 recommended), memorable passphrases are encouraged over complex short passwords.
- Composition rules have been removed, no mandatory uppercase, lowercase, numbers, or special characters are required.
- ASCII/Unicode characters are permitted, including spaces, to enable natural passphrases (e.g. "confusing cod posing idealist ungreased).
- Some passphrase generators can be used to generate true random passphrase [2]. Otherwise, Password Strength Meters (PSM) can be used to test the strength of the passphrase.[3]
- Password history is eliminated, users may reuse previous passwords after 6 months has passed.

4.3 Change Frequency

- Periodic password expiration is prohibited. Passwords must only be changed upon evidence of compromise or when automatically screened against known breached password lists during creation/reset.

4.6 Password Management Tools

- The use of approved password managers is really advised. These tools generate cryptographically secure passwords and store them with strong encryption, requiring users to protect only one strong master password [4].

4.7 Multi-Factor Authentication

- MFA is mandatory for all accounts where technically feasible, prioritising biometric authentication (fingerprint/face recognition) or using access keys as hardware security keys over SMS-based MFA [4].

4 Motivations for Changes

Behind each change there is a specific motivation, first this assessment follows the new NIST standard for Authentication. Indeed, in July 2025, the NIST revised their password guidelines with the NIST Special Publication 800-63B [5] representing a major shift in password policy design. They removed the mandatory complexity rules (uppercase, numbers, symbols), replaced them with a length-based password of 12-16+ characters, recommending passphrases, as longer passwords resist brute-force attacks exponentially better. Also, they no longer recommend

forced periodic expiration, as routine changes lead users to create predictable variations like "Password1" to "Password2," reducing effectiveness. Passwords should only change upon evidence of compromise, one comparison that can be made is that you do not change the key to your house because nobody has robbed it in the last 90 days. These reasons motivate my choice for the password construction and password expiration policy.

From a user-centric security perspective this new password construction policy may also increase cognitive load for some users, this means that the policy should not rely on password length alone, but should also include supporting measures such as password managers and multi-factor authentication.

As explained in the previous section, implementing this type of software is recommended by the NIST [5] or the Cybok [4] and has numerous advantages. They can help users to generate, store and retrieve strong passwords. The passwords created are generated with secure random number generation and encrypted with secure encryption. In addition to that, the main advantage of a password manager is that users can have very robust passwords but only need to know one main password. Thus, users would be more inclined to have and remember one strong password/passphrase. This is really important in terms of accessibility for elderly people, people with dyslexia, and others with cognitive or memory difficulties. There are different types of password managers: Local side (e.g. KeePassXc) or server side with paid services (e.g. 1Password, BitWarden) or Open Source services (e.g. VaultWarden).

Additionally instead of requiring only the password, multi-factor authentication systems require users to present multiple factors during the authentication process. according to this report from Microsoft in 2023 [6], using MFA reduces the risk of compromise by 99.22% across the entire population and by 98.56% in cases of leaked credentials. This results, added to the NIST guideline motivate my choice of implementing MFA into the changes.

5 Conclusion

Across this assessment, we have seen the strengths and the weaknesses of the City of Jonesboro's Password policy. Overall, the policy addresses basic password hygiene well and shows good intent, but its reliance on outdated password-rotation and complexity rules reduces usability and may not improve real security outcomes.

References

- [1] "City of jonesboro - password policy." <https://www.jonesboroar.gov/DocumentCenter/View/4253/Password-Policy-PDF>.
- [2] "Use a passphrase." <https://www.useapassphrase.com/>.
- [3] "Password monster." <https://www.passwordmonster.com/>.
- [4] National Cyber Security Centre (NCSC), *The Cyber Security Body of Knowledge*. National Cyber Security Centre, 1.1.0 ed., July 2021. Version 1.1.0.
- [5] National Institute of Standards and Technology, "Digital identity guidelines: Authentication and lifecycle management," Tech. Rep. NIST Special Publication 800-63B, National Institute of Standards and Technology, June 2017.
- [6] L. A. Meyer, S. Romero, G. Bertoli, T. Burt, A. Weinert, and J. Lavista Ferres, "How effective is multifactor authentication at deterring cyberattacks?," tech. rep., Microsoft, 2023. Microsoft Research Paper.